

Orion - Progress Report

Reporting period: 26 August-2 September 2026

Status: Completed synthetic-demo milestone; not approved for real users or real clinical use

A concise owner-facing summary of the completed synthetic-demo milestone, its verification evidence, and the decisions needed before any real-user use.

Important boundary

This report describes a controlled Orion demonstration built with synthetic accounts and synthetic data only. It does not authorise real patient information, real appointments, real clinical consultations, or production video sessions.

The work demonstrates that Orion can enforce protected sign-in, role-based access, appointment booking, patient cancellation, and tightly restricted demo video access. Moving beyond this boundary requires the owner, clinical, privacy, vendor, and operations decisions listed in this report.

Executive summary

Between 26 August and 2 September, Orion progressed from a front-end prototype into a five-account, fake-data demonstration with a protected database and server-controlled workflows.

The completed demo can show:

- Real sign-in for two synthetic patients, two synthetic psychiatrists, and one synthetic admin.
- Role-correct navigation and protected access to appointment information.
- Booking of 45-minute psychiatric appointments without double booking.
- Patient cancellation more than 24 hours before an appointment, with the slot reopened safely.
- A Jitsi as a Service (JaaS) video-call demonstration restricted to the booked synthetic patient and assigned synthetic psychiatrist.
- Audit records and repeatable automated and human checks covering the major demo paths.

The final unified **D6/D7 validation milestone** confirmed the fake-data demo through unit, database, access-control, browser, mobile, and live two-participant video checks. This is evidence that the demo works within its stated boundary-not a decision to launch a healthcare service.

Database overview

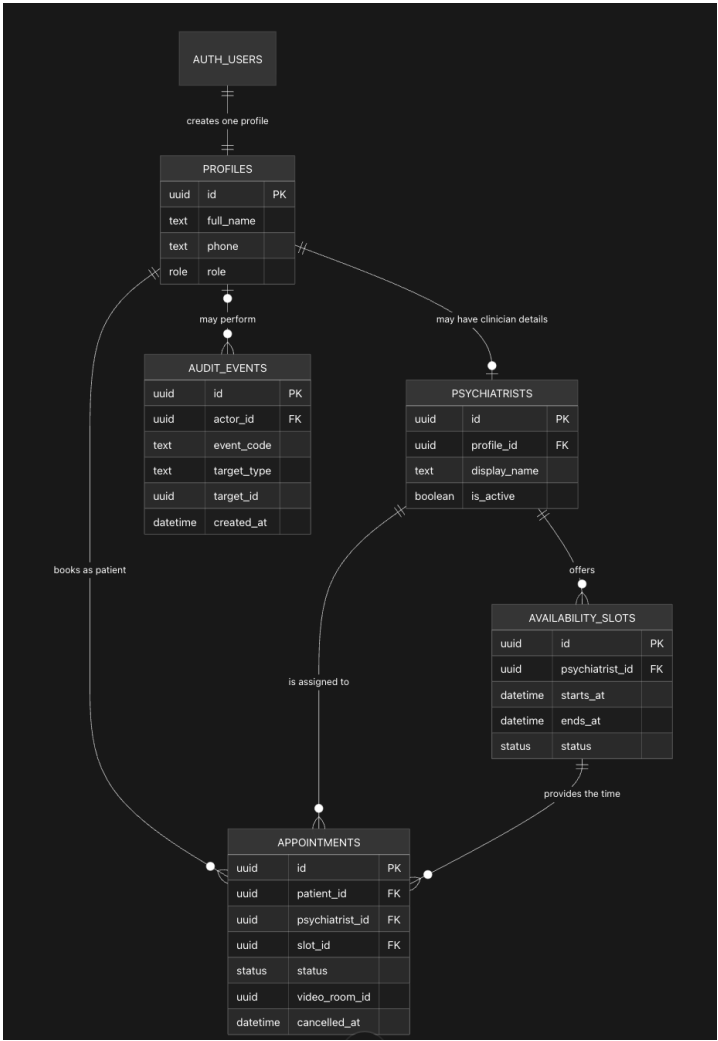


Figure 1. The Orion synthetic-demo database diagram: the protected links between sign-in accounts, profiles, availability, appointments, video access, and audit events.

The database is the protected source of truth for the demo. It connects identity, appointment availability, bookings, video access, and accountability without relying on what a browser screen says.

Area	Purpose	Key protection
Login account	Authenticates a person signing in	Password and session handling are provided by the protected identity service.
Profile	Defines whether the person is a patient, psychiatrist, or admin	A role is read from protected profile data; it is not inferred from an email address.
Psychiatrist record	Holds clinician-facing demo details and active status	Exists only for psychiatrist profiles.
Availability slot	Holds a psychiatrist's 45-minute availability	Overlap and booking rules are enforced in the database.
Appointment	Connects patient, psychiatrist, and selected slot	Becomes the source of truth for booking and cancellation status.

Area	Purpose	Key protection
Video-room reference	Associates an appointment with a non-public demo room	Room references are random and do not contain patient or appointment details.
Audit event	Records important actions and outcomes	Ordinary users cannot read the security/audit log.

In plain language: the database is both the filing system and a security checkpoint. A patient can access only their own appointments; a psychiatrist can access only appointments assigned to them. Important decisions such as booking, cancellation, and video admission are made by protected server functions, not solely by the browser.

Delivery timeline

Delivery	Date	Outcome delivered
D0 - Foundation	26-27 Aug	Established traceable version control, secret-handling protections, safe configuration examples, and a separate Orion synthetic-demo environment.
D1 - Database and access rules	28-29 Aug	Created the demo schema, five synthetic accounts, database migrations, Row-Level Security (RLS), appointment constraints, and protected audit records.
D2 - Identity and role access	30 Aug	Replaced mock sign-in with real authentication, server-held roles, role-specific navigation, and protected routes.
D3 - Booking	31 Aug	Delivered server-authoritative booking with transaction locking, idempotency, conflict prevention, Manila-time display, and appointment visibility rules.
D4 - Patient cancellation	31 Aug	Delivered patient cancellation more than 24 hours before an appointment, safe repeated requests, slot reopening, and audit events.
D5 - Synthetic video call	1-2 Sep	Delivered JaaS-based synthetic video access using short-lived participant tokens, random room references, restrictive meeting controls, and a server-side kill switch.
D6/D7 - Unified final validation	2 Sep	Completed the final access matrix, live desktop/mobile fake-call checks, transaction/RLS/browser testing, repeatable human cancellation checks, linting, build, and patch validation.

D0 - Project foundation

The project was made traceable and reversible before feature work began. Repository protections reduce the risk of passwords, private keys, login sessions, or scratch files being committed. The demo runs in an Orion-specific environment and contains fake data only.

D1 - Database, accounts, and access rules

The demo database supports profiles, psychiatrist records, availability slots, appointments, and audit events. The account set is intentionally limited to two synthetic patients, two synthetic psychiatrists, and one synthetic admin.

Database controls enforce a 45-minute session length, prevent overlapping availability and double booking, limit appointment visibility to the related patient or assigned psychiatrist, and prevent ordinary users from reading audit records.

D2 - Login, identity, and role-based screens

Orion now uses real authentication rather than a mock login. The system reads the signed-in person's role from the protected database and changes navigation accordingly. A user cannot acquire access by changing a URL, editing an email address, or creating a browser-side token.

D3 - Booking an appointment

Patients can view genuine synthetic availability in Manila time and request an appointment. The protected server workflow confirms the caller's role, briefly locks the target slot, verifies that it remains open, creates the appointment, marks the slot booked, and records a minimal audit fact as one transaction.

Repeated clicks or network retries are handled safely: the same booking reference returns the original outcome instead of creating a second appointment.

D4 - Cancelling an appointment

Patients may cancel more than 24 hours before an appointment. The server checks the time independently of the browser, then cancels the appointment, reopens the slot, records the relevant facts, and handles repeated requests without conflicting changes.

Psychiatrist cancellation, staff-assisted late cancellation, rescheduling, and no-show handling remain future policy and implementation work.

D5 - Fake-data video call

The demo uses JaaS only for a booked synthetic patient and their assigned synthetic psychiatrist. Before a meeting can open, Orion verifies that the user is signed in, is a valid participant, has an active appointment, is within the approved demo joining window, and that demo video mode is enabled.

Only then does Orion issue a short-lived, person-specific token. A copied room name alone does not admit someone to a call. Recording, transcription, chat, file transfer, screen sharing, invitations, and copy-link controls are disabled for this demo.

Security and privacy controls

Orion uses multiple complementary controls rather than relying on a single screen or password.

Control	What it does
Real authentication	Replaces the earlier pretend login with protected sign-in.
Role-based access	Gives patients, psychiatrists, and admins different permitted actions and navigation.
Database-level RLS	Limits each account to the data it is permitted to read or change.

Control	What it does
Protected server actions	Keeps booking, cancellation, and video-admission decisions out of the browser.
Server-held credentials	Keeps database and video-provider secrets out of browser storage and source-visible links.
Short-lived video tokens	Allows only the assigned synthetic participants into one time-limited demo meeting.
Restricted video features	Disables recording, transcript, chat, file transfer, screen share, invitations, and copy-link controls.
Audit facts	Records important outcomes without retaining unnecessary provider room names, URLs, or tokens.
Synthetic-data boundary	Ensures the demo uses no real patient, psychiatrist, appointment, or clinical-session data.

The result is a layered design: the app guides the person, the server authorises the action, and the database independently limits what data can be accessed or changed.

D6/D7 unified final validation

The final validation milestone on 2 September combined access-matrix, video-completion, database, browser, mobile, and human-check evidence for the five-account synthetic demo.

Video-access and live-call evidence

- The booked synthetic patient and assigned psychiatrist received short-lived demo access.
- Another patient, another psychiatrist, admin, signed-out users, cancelled appointments, disabled demo mode, before-window requests, and after-session requests were denied.
- A copied room name without a valid token did not join a JaaS conference.
- Separate authenticated desktop browser contexts completed the Orion join flow and reached a joined two-participant conference.
- The same two-participant check passed in separate Pixel 5 mobile browser contexts.
- After the patient left, the psychiatrist remained in the call; the patient re-entered successfully before the scheduled end.
- Browser routes, storage, console output, and test artifacts were checked for issued room names and JaaS tokens; no match was retained.

Automated and repeatable verification

Check	Result	What it confirmed
Unit tests	3 passed	45-minute duration, strict cancellation boundary, and meeting-window boundaries.
Booking database test	Passed	Idempotent retry and one successful booking when requests compete for one slot.
Cancellation database test	Passed	Ownership, 24-hour denial, idempotency, slot reopening, and audit behavior.
RLS database test	Passed	Only the related patient and assigned psychiatrist can read an appointment; protected roles cannot be changed by a patient.
Authenticated desktop/mobile scheduling tests	4 passed	Booking, psychiatrist visibility, and cancellation using isolated synthetic fixtures.
Public/unauthenticated browser suite	14 passed	Public navigation and protected-route behavior on desktop and mobile.
Lint	Passed	Source and test configuration are lint-clean.
Production build	Passed	Production build completed; the existing bundle-size warning remains.
Patch whitespace check	Passed	No whitespace errors in the working patch.

Repeatable human checks

The normal booking/cancellation path and the within-24-hours cancellation denial were completed successfully with fixed synthetic accounts. A repeatable seed/checklist process now refreshes only its recorded synthetic fixtures.

Remaining demonstration item

The five-account owner walkthrough is intentionally deferred until the frontend changes are accepted. It is a final showcase for owners-not missing technical verification and not approval for real-world use.

Decisions and open questions

The technical demo is complete, but the following are business, clinical, legal, and privacy choices that engineering should not make alone. They determine what Orion may do with real people in the future.

1. Name the clinical lead and approve psychiatrists

Orion needs a named, licensed clinical lead: one person who owns clinical safety decisions and the process for deciding whether a psychiatrist may use the service.

- **Decision needed:** Name the clinical lead; decide who checks psychiatrist credentials, how often checks are renewed, and who can approve, suspend, or reactivate a psychiatrist.
- **Why it matters:** A real service needs clear clinical accountability. The system cannot safely decide who is qualified to provide care.
- **Until this is decided:** Orion should not host real sessions or provision real psychiatrists.

2. Agree the rules for late arrivals, no-shows, and late cancellation

The demo shows booking and patient cancellation. The remaining appointment rules need an owner and clinical decision before they are built.

- **Decision needed:** Confirm the grace period before someone is marked absent; decide the early-join window, what happens when a session ends, and who may handle a psychiatrist's late cancellation.
- **Current starting point:** A 15-minute grace period is recommended. A psychiatrist should decide a no-show rather than the system marking it automatically.
- **Until this is decided:** The later cancellation and post-session parts of the appointment workflow should not be finalised.

3. Decide how long information is kept and what deletion means

Real healthcare-related information may need to be kept for a required period, even if an account is closed or a person asks for deletion. Orion needs clear rules before it collects such information.

- **Decision needed:** Set retention periods for account details, appointments, consents, audit records, session notes, backups, and security logs. Decide what is deleted, anonymised, or retained after account closure or a deletion request.
- **Why it matters:** Session notes may have special clinical record-keeping requirements. This cannot be guessed by engineering.
- **Until this is decided:** Orion cannot implement a complete real-user retention or deletion process.

4. Identify the legal operator and privacy lead

Owners need to identify the company legally responsible for Orion and appoint the person responsible for privacy governance (often called a Data Protection Officer, or DPO).

- **Decision needed:** Name the legal operating entity, appoint the privacy lead/DPO, and confirm the legal basis for handling scheduling details, session notes, and optional communications.
- **Why it matters:** Someone must be formally responsible for protecting personal information and approving privacy decisions.
- **Until this is decided:** Orion must not process real personal information or launch to real users.

5. Approve what patients will see and agree to

The structure of the patient agreements is agreed, but the final words still need approval. Patients need clear, understandable information before they use a real service.

- **Decision needed:** Approve the privacy notice, telepsychiatry consent, optional communications wording, crisis/referral information, and explanation of how session notes work.

- **Why it matters:** Patients should understand what Orion collects, what an online session involves, where to get urgent help, and who can access their information.
- **Until this is decided:** Real sign-up and first-session workflows should not be enabled.

6. Choose and approve technology suppliers for real use

JaaS is used only for this restricted fake-data demonstration. It is not yet an approved provider for real consultations.

- **Decision needed:** Choose a video provider for real sessions and approve the terms for the database and video suppliers, including data location, subcontractors, breach/outage support, and retention/deletion commitments.
- **Why it matters:** Real patient information must only be handled by suppliers whose terms and safeguards are acceptable to Orion's owners and privacy advisers.
- **Until this is decided:** No real video sessions or production vendor use should begin.

7. Decide who supports users and who can stop the service

When a real user needs help, or when there is a security, clinical, or technical issue, the team needs to know who acts and who has the authority to pause the service.

- **Decision needed:** Set support hours, clinical and security escalation contacts, client communication responsibilities, and who can stop bookings or video when needed.
- **Current starting point:** A secretary role is agreed in principle for bookings and client questions, but not for access to clinical notes.
- **Until this is decided:** Orion cannot complete its real-user support and incident-response processes.

8. Set the first launch boundary and review process

The intended first real-user service is adults-only, with people confirming their own age. Owners still need to decide where it may operate and how its activity will be reviewed.

- **Decision needed:** Approve the launch geography and decide how often the team reviews demand, quality, and the need for scaling work.
- **Why it matters:** A clear first boundary helps the team manage demand before it affects quality or reliability.
- **Until this is decided:** The real-user launch scope remains incomplete.

9. Finalise the secretary role and any future demo expansion

The current demonstration has five synthetic accounts and does not demonstrate session notes. A future phase may add a secretary, but its exact access needs a decision first.

- **Decision needed:** Decide whether secretaries are assigned per psychiatrist or clinic-wide; whether they may book or cancel for patients; whether they may see that a note exists; and whether a sixth synthetic secretary account or session-note view belongs in a future demo.
- **Current boundary:** Secretaries may see appointment and contact details, but must never read session-note content.
- **Until this is decided:** The secretary role and any expanded demo scope will remain unbuilt.

10. Confirm the visual direction of the app

The current demo has an established login-page image, overall theme, and colour palette. Before further design work, it would be useful to know whether owners want that direction retained or want a different visual identity.

- **Decision needed:** Should the app keep its current login image, theme, and colour palette, or do you have a specific look, reference, brand guide, colours, or imagery you would like to use instead?
- **Why it matters:** Early direction avoids redesign work later and helps ensure the product feels consistent with the owners' intended brand.
- **Until this is decided:** The current visual direction will remain in place for future interface work.

Not included or approved for real use

The current demo does **not** include or authorise:

- Real patient data, real appointments, real patient sign-up, or real clinical consultations.
- Session notes in the demo.
- A secretary account in the demo.
- Prescriptions, diagnoses, recordings, transcripts, chat, file uploads, or reasons for visit.
- A production-approved video provider or production vendor agreements.
- Production operations, incident-response processes, retention/deletion processes, or support runbooks.

Before Orion can accept real users, company owners need to close the recorded clinical, legal/DPO, privacy, vendor, retention, patient-wording, support, geography, and real-session video decisions.

Recommended next steps

1. Review this report and complete the five-account owner walkthrough once the frontend is accepted.
2. Hold the rescheduled owner meeting using the open-decision questions above.
3. Record each decision, owner, and approval date in the Pilot Decision Register.
4. Prioritise clinical lead appointment, legal/DPO ownership, and vendor approval because they are hard launch gates.
5. Authorise only the next implementation work that follows from recorded owner and clinical decisions.

Appendix A - Evidence sources

Delivery summaries

- D0 - Project foundation
- D1 - Database, accounts, and access rules
- D2 - Login, identity, and role-based screens
- D3 - Booking an appointment
- D4 - Cancelling an appointment
- D5 - Fake-data video call

Dated audit evidence

- 26 Aug - React UX implementation audit
- 27 Aug - Production readiness foundation audit
- 28 Aug - Supabase demo foundation audit
- 29 Aug - Synthetic demo-account provisioning audit
- 30 Aug - Real demo identity audit
- 30 Aug - Role-navigation simplification audit
- 31 Aug - D3 database-backed scheduling audit
- 31 Aug - D4 patient cancellation audit
- 1 Sep - D5 JaaS implementation audit
- 1 Sep - D5 deployment and early-join audit
- 2 Sep - D5 access-matrix audit
- 2 Sep - D5 video completion audit
- 2 Sep - D7 synthetic-demo verification audit

Owner decision source

- Pilot Decision Register